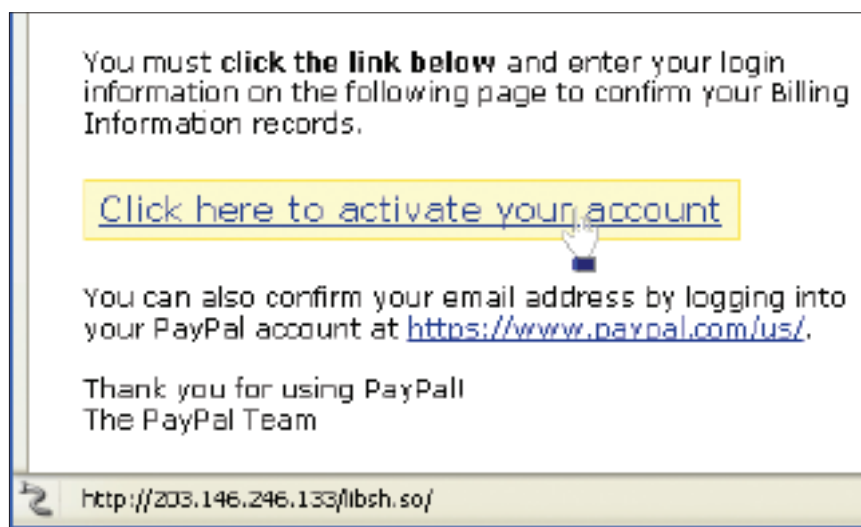


window of a legitimate website. This means that, again, the page you are viewing is the correct one, with the correct URL and with the security icon visible, if relevant. But, part of it has been replaced with malicious purpose. This can be very difficult to spot.

In these types of attack, the malicious code is inserted in such a way that it runs in your browser — the server of the bank or other service has not been compromised. However, there is a form of attack known as remote code execution in which the web application is itself tricked into executing the attacker's code. Very often, this results from weaknesses in PHP, one of the most common scripting languages used for creating web sites. Again, the relevant scripts can be triggered from within manipulated URLs. Many programmers have simply assumed that their program will always receive valid input data at all times, and do insufficient validation of such



data: URLs, form data, and so on.

Many, if not all, of the websites with which we are likely to have online transactions are backed by large SQL databases. Again, problems occur when data that a user might input is not filtered and checked properly by the web site. If this data has been manipulated in some way, a skilled attacker can make use of special SQL characters (typically, the comment and end-of-command characters) and infiltrate his own commands in order to execute an attack. With this kind of attack, it is the web service that is the target, rather than the user directly. However, there have been instances where attackers have been able to compromise an SQL database and access customers' credit card and transaction details.

Another component in online transactions that is supposed to safeguard such details, and that has attracted attention in

This second partial screenshot is from a phishing email, pretending to come from PayPal. Notice that the actual link that would be followed — in the window frame — is very different from the one in the email text. This would for certain lead to a spoofed site of some kind, with a request to enter personal data. Always check the actual link when following a link in an email, and if it is for a site involving financial transactions, never click on such a link

the last year, is security certification. If you are online to an e-commerce site and are about to enter your credit card information, the window you are working in should have a little lock icon in the bottom right corner of the frame. This is the security certificate, and strictly speaking, you should click on the icon, and check that the certificate is genuine and was issued to the right organisation. This is a pain, and there must be very few people who actually bother to do this, or even know that it might be a wise thing to do. Such checks are being introduced into browsers, but this has been very slow in coming.

You may think these security certificates are rock solid and reliable, but earlier this year, the commonly used OpenSSL package in Debian — used to generate the keys for this kind of encrypted communication — was found to have contained a bug since 2006. This resulted in the creation of weak keys. This makes the

keys more predictable and the communication therefore open to attack; the communication over which your credit card or other details might be passed.

Finally, although our list of security vulnerabilities is going to be far from comprehensive, we should mention keyloggers, which are a particularly pernicious form of infiltrated software. You might pick up a keylogger in much the same way as a virus, trojan or worm. Once it is inside your system, it will do nothing to give away its presence, but it will sit there noting the keystrokes that are made and sending these off across the internet to the attacker. Of course, it will be looking for the tell-tale signs of credit card or banking information and the relevant PINs and passwords. It is

because of attacks such as these that some banks have started supplying virtual keyboards when you enter your password. With these, instead of using your physical keyboard to enter the password you use the keyboard on screen, pressing keys with the mouse. The keylogger is blind to this activity — at least up until now!

It should be clear by now that the complexity of modern computer systems carries with it a vast number of possibilities for attackers to infiltrate systems and gain access to confidential data. The increasing trend towards such concepts as cloud computing and Web 2.0, involving more private data being hosted on the internet and ever more code and transactions being passed across the internet, is only likely to make the situation worse. In the following pages we describe the steps you can take to protect yourself in that dangerous online world, and the software that can help you on the way. ■